SECCIÓN 8.3

Documentación trazable y útil

Temas de esta sección:

- Para qué sirve la documentación en un SOC
- Qué debe incluir una documentación de calidad
- Handoff: cómo transferir un análisis sin perder contexto
- Documentación de IOCs: qué incluir y qué no
- Ejercicio: documentar un caso real

8.3 | Calidad del análisis: estándares mínimos

Documentación de calidad incluye:

- Se identifica el activo afectado con nombre, IP y rol
- Se registran timestamps con zona horaria
- Se separan hechos de hipótesis
- Se documenta lo revisado y lo descartado
- Se indica el nivel de certeza de cada conclusión
- Se incluyen IOCs con contexto (no solo la lista)
- El estado del caso es claro: abierto / cerrado / escalado
- Cualquier analista puede continuar desde la documentación

Esto NO es documentación suficiente:

- "Revisado — OK"
- "Parece limpio"
- "Falso positivo" sin justificación
- Copia de alertas sin análisis
- Sin timestamp ni fuente
- Conclusión sin evidencia de soporte

Un handoff exitoso es aquel en el que el analista que recibe puede continuar sin necesidad de preguntar lo básico.

¿Qué pasó?

- Alerta o evento original
- Activo involucrado
- Timeline de eventos

¿Qué se revisó?

- Evidencia analizada
- Fuentes consultadas
- IOCs identificados

¿Qué se descartó?

- Hipótesis eliminadas
- Razón del descarte
- Evidencia contradictoria

¿Qué falta?

- Revisiones pendientes
- Datos faltantes
- Escalamientos requeridos

Un IOC sin contexto es ruido. Un IOC con contexto es inteligencia operativa.

```
IOC: 185.220.101.44

Contexto documentado:
  Tipo: IP externa
  Vista en: HR-LAP-044, conexión saliente puerto 443, activa 18 min
  Primer visto: 2026-10-13 14:22 UTC
  Proceso origen: powershell.exe (child de wscript.exe → OUTLOOK.EXE)
  Clasificación: probable C2 — reputación baja (TI: abuso reportado)
  Acción tomada: host aislado, pendiente análisis de tráfico completo
```

Qué incluir

- Tipo de IOC (IP, hash, dominio, archivo, ruta)
- Dónde se vio (host, usuario, proceso, conexión)
- Timestamp y zona horaria
- Proceso origen y contexto de ejecución
- Clasificación y nivel de certeza
- Acción tomada o recomendada

Qué evitar

- Listar IOCs sin contexto de dónde se vieron
- No indicar si fue validado o solo observado
- Mezclar IOCs confirmados con indicios
- Sin timestamp ni proceso origen
- Acción no documentada

8.3 | Ejercicio: documentar un caso real

Leé la evidencia y completá qué documentarías y cómo la comunicarías en un handoff:

```
Evidencia disponible:
Host: HR-LAP-044 (usuario: jlopez, RRHH)
Cadena: OUTLOOK.EXE → wscript.exe → powershell.exe
Archivo: C:\Users\jlopez\Downloads\CV_Candidato.js
Conexión externa: 185.220.101.44:443 (activa, 18 min)
Archivo adicional: C:\Users\Public\svchost32.exe
Score SIEM: 87/100
No hay ticket de soporte ni cambio aprobado
```

¿Qué documentarías?

- Activo y usuario: HR-LAP-044, jlopez, RRHH
- Cadena de procesos completa con timestamps
- Archivo sospechoso y ruta exacta (CV_Candidato.js)
- Conexión externa: IP, puerto, duración
- svchost32.exe en ruta Public (no estándar)
- Validaciones realizadas: sin ticket, sin cambio aprobado
- Nivel de certeza: probable compromiso vía phishing

Mensaje de handoff esperado:

"HR-LAP-044 (jlopez, RRHH): OUTLOOK → wscript → powershell desde CV_Candidato.js. Conexión externa activa (185.220.101.44). Artifact en C:\Users\Public\svchost32.exe. Sin ticket. Probable initial access vía phishing. Pendiente: análisis del .js, revisión del binario en Public y contención. Score 87."